

Investigación Sobre Implementación de DHCP Snooping

Integrante:

Doglio Ramiro Matías matiasdoglio@gmail.com

Metodos de Ataque

Ataque de inanición de DHCP (DHCP Starvation Attack)

¿En qué consiste? El atacante genera una gran cantidad de solicitudes DHCP falsas, cada una con una dirección MAC de origen diferente (spoofed), agotando todo el pool de direcciones IP del servidor DHCP legítimo .

Consecuencias:

- Denegación de servicio (DoS) para clientes legítimos
- El atacante puede luego instalar un **servidor DHCP malicioso** (rogue DHCP server) para interceptar tráfico
- Puede combinarse con ataques **Man-in-the-Middle**

¿Cómo se ve en la práctica? Herramientas como Yersinia o DHCPstarv permiten realizar este ataque fácilmente.

Servidor DHCP Rogue (No autorizado)

¿En qué consiste? Un dispositivo no autorizado (un router WiFi mal configurado, una laptop con servidor DHCP activado, o un atacante con una Raspberry Pi) se conecta a la red y comienza a asignar direcciones IP .

¿Por qué es peligroso? Muchos usuarios conectan routers WiFi personales sin saber que tienen DHCP activado. Esto puede ocurrir **sin intención maliciosa**, pero igualmente causa problemas de conectividad .

Escenario más grave (malicioso): El atacante configura un servidor DHCP que asigna:

- **Gateway = IP del atacante** → todo el tráfico pasa por él (Man-in-the-Middle)
- **DNS = IP del atacante** → redirige sitios web a páginas falsas (phishing)

Ataque de falsificación de solicitud DHCP (Forged DHCP Request)

¿En qué consiste? Un atacante envía un mensaje DHCP RELEASE o DHCP DECLINE en nombre de un cliente legítimo, liberando su dirección IP y causando que el cliente pierda conectividad .

Mecanismos de defensa (DHCP Snooping) {#defensas}

Para protegerte de estos ataques, existe una tecnología clave llamada **DHCP Snooping**.

¿Qué es DHCP Snooping?

Es una característica de seguridad implementada a nivel de **switch de capa 2** que filtra mensajes DHCP no confiables .

Reglas simples :

- **Trusted Ports** → Se permiten **todos** los mensajes DHCP (incluyendo DHCP OFFER, DHCP ACK). Solo para puertos conectados al servidor DHCP legítimo o a routers confiables.

- **Untrusted Ports** → Se **bloquean** mensajes de servidor (DHCPOFFER, DHCPACK, DHCPNAK). Solo se permiten mensajes de cliente (DHCPDISCOVER, DHCPREQUEST, DHCPRELEASE).

Binding Database (Base de datos de vinculación)

Cuando DHCP Snooping está activado, el switch construye automáticamente una base de datos que vincula :

Campo	Descripción
MAC address	Dirección MAC del cliente
IP address	IP que se le asignó
Lease time	Tiempo de concesión
VLAN	VLAN del cliente
Interface	Puerto por donde está conectado

Esta base de datos también es utilizada por **Dynamic ARP Inspection (DAI)** para prevenir ataques ARP Poisoning.

Opción 82 (Relay Agent Information)

¿Qué es? Una opción que el relay agent (switch o router) agrega a los mensajes DHCP para identificar **dónde** está conectado el cliente

Utilidad :

- El servidor DHCP puede asignar IPs según **dónde** está el cliente
- Permite políticas de seguridad por ubicación
- Ayuda en entornos de acceso público (hoteles, universidades)

Extensiones y opciones avanzadas de DHCP {#extensiones}

Como medida de seguridad se eligió DHCP Snooping.

La configuración se realizó siguiendo los siguientes comandos:

- ip dhcp snooping: Habilitar DHCP Snooping globalmente.
- ip dhcp snooping vlan 1: Habilitar para la VLAN específica (ej. VLAN 1)
- ip dhcp snooping trust: Configurar el puerto hacia el servidor DHCP como TRUSTED
- ip dhcp snooping limit rate 10: Limitar tasa de solicitudes en puertos untrusted.
- no ip dhcp snooping information option: Desactivar la inserción de Option 82.

```
Switch(config)#ip dhcp snooping
Switch(config)#ip dhcp snooping vlan 1,10,20,30
```

```
Switch(config)#interface FastEthernet0/1
Switch(config-if)#ip dhcp snooping trust
Switch(config-if)#no ip dhcp snooping limit rate
```

```
Switch(config)#interface FastEthernet0/17
Switch(config-if)#ip dhcp snooping trust
Switch(config-if)#no ip dhcp snooping limit rate
```

```

Switch(config)#interface range FastEthernet0/2-16
Switch(config-if-range)#ip dhcp snooping limit rate 15

Switch(config)#interface range FastEthernet0/18-24
Switch(config-if-range)#ip dhcp snooping limit rate 15

Switch(config)#no ip dhcp snooping information option

Switch(config)#do show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
1,10,20,30
Insertion of option 82 is disabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled

```

Interface	Trusted	Rate limit (pps)
FastEthernet0/2	no	15
FastEthernet0/3	no	15
FastEthernet0/1	yes	unlimited
FastEthernet0/6	no	15
FastEthernet0/7	no	15
FastEthernet0/4	no	15
FastEthernet0/5	no	15
FastEthernet0/8	no	15
FastEthernet0/12	no	15
FastEthernet0/9	no	15
FastEthernet0/10	no	15
FastEthernet0/11	no	15
FastEthernet0/16	no	15
FastEthernet0/15	no	15
FastEthernet0/13	no	15
FastEthernet0/14	no	15
FastEthernet0/20	no	15
FastEthernet0/18	no	15
FastEthernet0/19	no	15
FastEthernet0/17	yes	unlimited
FastEthernet0/21	no	15
FastEthernet0/22	no	15
FastEthernet0/23	no	15
FastEthernet0/24	no	15

Recuperación automática (útil en entornos de producción): Configurar el switch para que reactive el puerto automáticamente después de un tiempo.

```
errdisable recovery cause dhcp-rate-limit
```

```
errdisable recovery interval 300
```

Esto no lo configuramos ya que Packet Tracer no lo admite.

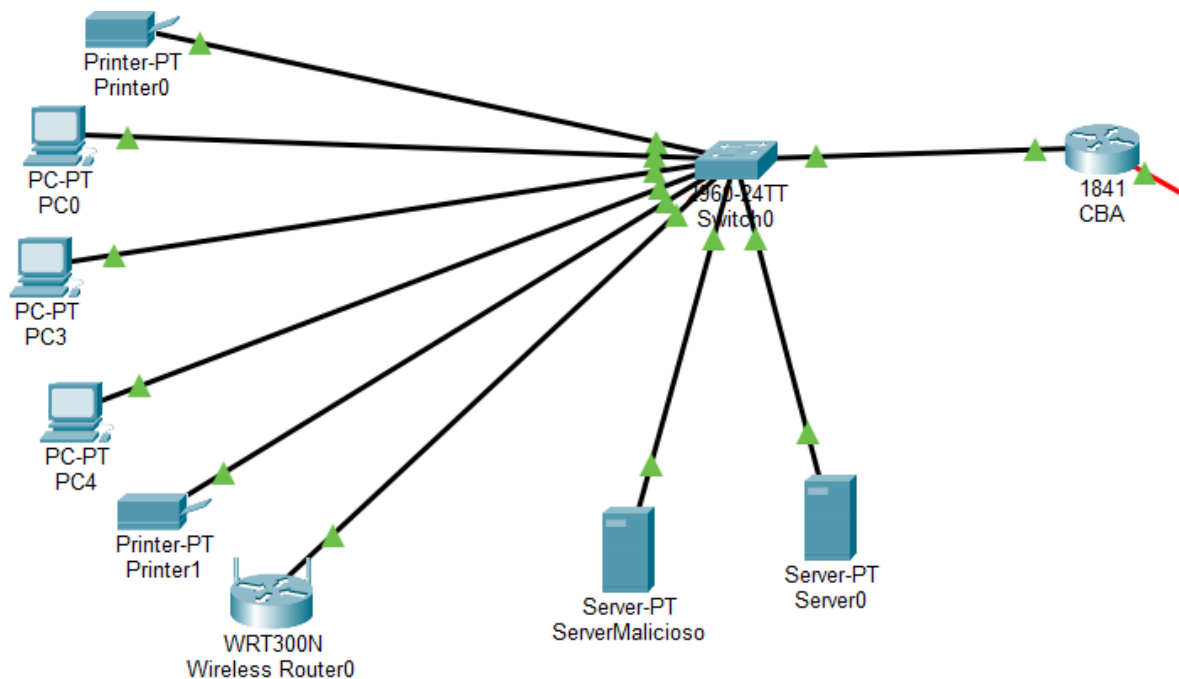
Recuperación manual (la más común en laboratorios): Entrar a la interfaz del switch y reactivarla manualmente.

```
interface fastEthernet 0/2
```

```
shutdown
```

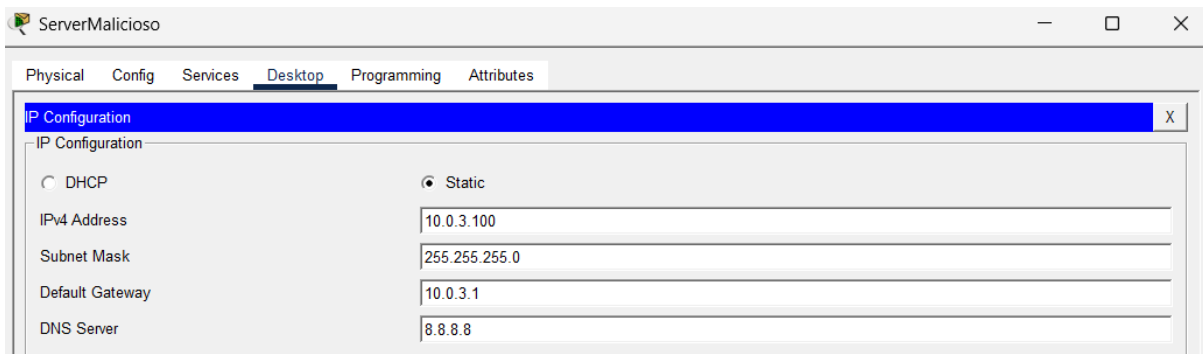
```
no shutdown
```

Para la demostración de cómo funciona el ataque **Rogue DHCP Server** vamos a utilizar una red como prueba en la que no hayamos configurado todavía el DHCP Snooping, en este caso elegimos la red de Córdoba.



Como se puede ver en la imagen conectamos un Server-PT de nombre ServidorMalicioso para simular un atacante.

Se realiza la configuración IP del ServidorMalicioso, se le coloca una IP dentro del pool real que esta en funcionamiento:



Configuración del pool DHCP en el ServidorMalicioso:

Este pool se debe configurar en un rango que no este dado por el otro servidor o si podría hacerse, dependiendo de lo que el atacante desee hacer, como Gateway se le va a dar la IP del servidor del atacante ya que de esta forma actuaría como un “Man-In-The-Middle”.

DHCP

Interface: FastEthernet0 Service: ☒ On ☐ Off

Pool Name: serverPoolMalicioso

Default Gateway: 10.0.3.100

DNS Server: 8.8.8.8

Start IP Address: 10 0 3 102

Subnet Mask: 255 255 255 0

Maximum Number of Users: 50

TFTP Server: 0.0.0.0

WLC Address: 0.0.0.0

Pool Name	Default Gateway	DNS Server	Start IP Address	Subnet Mask	Max User	TFTP Server	WLC Address
serverPool	0.0.0.0	0.0.0.0	0.0.0.0	0.0.0.0	0	0.0.0.0	0.0.0.0
serverPoolMalicioso	10.0.3.100	8.8.8.8	10.0.3.102	255.255.255.0	50	0.0.0.0	0.0.0.0

En este momento, si los dispositivos realizan la petición DHCP veremos que se asignan tanto IPs y mascararas de los dos servidores, dependiendo del que haya respondido primero.

Caso de una impresora Printer0:

- En este caso, el dispositivo recibió la respuesta del servidor correcto:

Gateway/DNS IPv4

☒ DHCP ☐ Static

Default Gateway: 10.0.3.1

IP Configuration

☒ DHCP ☐ Static

IPv4 Address: 10.0.3.4

Subnet Mask: 255.255.255.0

Caso de una PC0:

- Acá, el dispositivo recibió la respuesta del servidor malicioso:

IP Configuration

☒ DHCP ☐ Static DHCP request successful.

IPv4 Address: 10.0.3.102

Subnet Mask: 255.255.255.0

Default Gateway: 10.0.3.100

DNS Server: 8.8.8.8

(Se colocaron solamente 2 dispositivos para no alargar tanto la documentación)

Ahora vamos a realizar la configuración del DHCP Snooping para el Switch0 de CBA.

```

Switch(config)#ip dhcp snooping
Switch(config)#ip dhcp snooping vlan 1
Switch(config)#interface FastEthernet0/1
Switch(config-if)#ip dhcp snooping trust
Switch(config-if)#no ip dhcp snooping limit rate

Switch(config)#interface FastEthernet0/7
Switch(config-if)#ip dhcp snooping trust
Switch(config-if)#no ip dhcp snooping limit rate
Switch(config-if)#interface range FastEthernet0/2-6
Switch(config-if-range)#ip dhcp snooping limit rate 15

Switch(config)#interface range FastEthernet0/8-24
Switch(config-if-range)#ip dhcp snooping limit rate 15

Switch(config)#no ip dhcp snooping information option
Switch(config)#do show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
1
Insertion of option 82 is disabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                Trusted      Rate limit (pps)
-----
FastEthernet0/17         no          15
FastEthernet0/19         no          15
FastEthernet0/18         no          15
FastEthernet0/21         no          15
FastEthernet0/22         no          15
FastEthernet0/20         no          15
FastEthernet0/2          no          15
FastEthernet0/3          no          15
FastEthernet0/4          no          15
FastEthernet0/5          no          15
FastEthernet0/6          no          15
FastEthernet0/7          yes         unlimited
FastEthernet0/9          no          15
FastEthernet0/10         no          15
FastEthernet0/11         no          15
FastEthernet0/1          yes         unlimited
FastEthernet0/8          no          15
FastEthernet0/12         no          15
FastEthernet0/13         no          15
FastEthernet0/14         no          15
FastEthernet0/15         no          15
FastEthernet0/16         no          15
FastEthernet0/24         no          15
FastEthernet0/23         no          15

```

Luego de realizar la configuración podremos ver que los dispositivos ya pueden recibir IPs y el Gateway correcto.

Caso de la impresora:

Gateway/DNS IPv4

☒ DHCP

☐ Static

Default Gateway | 10.0.3.1

IP Configuration	
☒ DHCP	
☐ Static	
IPv4 Address	10.0.3.3
Subnet Mask	255.255.255.0

Caso de la PC:

IP Configuration	
☒ DHCP	☐ Static DHCP request successful.
IPv4 Address	10.0.3.101
Subnet Mask	255.255.255.0
Default Gateway	10.0.3.1
DNS Server	8.8.8.8

Conclusión

En esta cuarta parte de la investigación, se abordó la seguridad del servicio DHCP, analizando los principales vectores de ataque y la implementación de DHCP Snooping como mecanismo de defensa en switches de capa 2.

Ataques estudiados:

Ataque	Descripción	Impacto
DHCP Starvation	Agotamiento del pool de direcciones IP mediante solicitudes masivas con MACs falsas.	Denegación de servicio (DoS) para clientes legítimos.
Rogue DHCP Server	Servidor DHCP no autorizado que asigna configuraciones maliciosas.	Man-in-the-Middle, redirección de tráfico, phishing.
Forged DHCP Request	Envío de mensajes DHCP RELEASE o DHCP DECLINE en nombre de un cliente legítimo.	Pérdida de conectividad del cliente.

Solución implementada: DHCP Snooping

DHCP Snooping convierte al switch en un "portero" que solo permite mensajes de servidor DHCP por puertos previamente definidos como **trusted**. Los puertos de clientes (**untrusted**) solo pueden enviar mensajes de solicitud (DHCPDISCOVER, DHCPREQUEST), bloqueando cualquier intento de respuesta de servidores no autorizados.

Configuración aplicada:

! Habilitar DHCP Snooping

```
ip dhcp snooping
```

```
ip dhcp snooping vlan 1,10,20,30
```

! Puerto del router (TRUSTED)

```
interface fastEthernet 0/1
```

```
ip dhcp snooping trust
```

! Puerto del servidor legítimo (TRUSTED)

```
interface fastEthernet 0/17
```

```
ip dhcp snooping trust
```

! Puertos de clientes (UNTRUSTED) con rate limiting

interface range fastEthernet 0/2 - 16

ip dhcp snooping limit rate 15

Demostración práctica:

- **Antes de DHCP Snooping:** Clientes obtenían IPs tanto del servidor legítimo como del Rogue Server, dependiendo de cuál respondía primero. Esto demostraba el caos y riesgo de un servidor no autorizado.
- **Después de DHCP Snooping:** Los clientes solo obtenían IPs del servidor legítimo. El Rogue Server seguía intentando responder, pero el switch bloqueaba sus DHCP OFFER en los puertos untrusted.

Limitaciones identificadas en Packet Tracer:

1. **Recuperación automática de puertos:** El comando `errdisable recovery cause dhcp-rate-limit` no está soportado en Packet Tracer. En un entorno real, este comando permite que un puerto desactivado por exceder el rate limit se reactive automáticamente tras un tiempo configurable (ej. 300 segundos). En Packet Tracer, la recuperación debe hacerse manualmente con `shutdown / no shutdown`.
2. **Option 82 y DHCP Relay:** En escenarios con DHCP Relay, el switch con DHCP Snooping intenta agregar la Option 82 (información de ubicación del cliente) a los paquetes DHCP. Esto puede causar conflictos con el relay del router, ya que ambos intentan proporcionar información de ubicación. La solución es desactivar la inserción de Option 82 en el switch con el comando:

bash

no ip dhcp snooping information option

Recomendaciones para entornos reales:

- **Habilitar DHCP Snooping en todos los switches de acceso.** Es una medida de bajo costo y alta efectividad.
- **Configurar rate limiting en puertos untrusted** con valores no mayores a 15 pps para clientes y hasta 100 pps para puertos confiables.
- **Desactivar Option 82 cuando se use DHCP Relay** para evitar conflictos de interpretación en el servidor.
- **Implementar recuperación automática** en equipos reales con `errdisable recovery cause dhcp-rate-limit` y un intervalo adecuado (ej. 300 segundos).
- **Combinar con otras medidas de seguridad:** DHCP Snooping es más efectivo cuando se complementa con **Dynamic ARP Inspection (DAI)** y **IP Source Guard**, que utilizan la base de datos de vinculación (binding database) generada por DHCP Snooping para prevenir ataques ARP y suplantación de IPs.

Estado final de la demostración:

- Se logró simular un ataque Rogue DHCP Server en una red sin protección.
- Se implementó DHCP Snooping correctamente en el switch.
- Se verificó que el Rogue Server quedó bloqueado, sin poder asignar IPs a los clientes.
- Se documentaron las limitaciones de Packet Tracer y las soluciones aplicadas.

Conclusión:

DHCP Snooping es una herramienta fundamental y de fácil implementación para proteger la capa de acceso de la red contra servidores DHCP no autorizados y ataques de inanición. Su uso debe considerarse una práctica estándar en cualquier red empresarial, junto con otras medidas de seguridad como DAI y Port Security. Aunque Packet Tracer tiene limitaciones para simular ciertas funcionalidades avanzadas (como la recuperación automática), los conceptos aprendidos son plenamente aplicables en entornos reales, donde estas características están disponibles y son altamente recomendadas.